

Week 6 Day 3

Security Testing Tools

i) Burp Suite

It is a web application security testing tool used for vulnerability assessment and Penetration testing. It enables both manual and automated security testing.

- Intercepts and analyzes HTTP/HTTPS traffic
- Scans web application for security vulnerabilities
- Includes tools like Proxy, Repeater, Intruder

Features of Burp Suite

i) Spider

Automatically crawls a web application to discover pages, link, directories, and endpoints, helping tester to understand its structures

ii) Proxy

Intercepts HTTP/HTTPS traffic between the browser and server; allowing testers to inspect and modify requests and responses.

iii) Intruder

It is a automated attack tool used for testing input field with multiple payload, like Brute force attack, Dictionary attack, SQL injection, XSS testing and Rate limit testing.

iv) Repeater

It allows testers to manually modify and resend HTTP request repeatedly to analyze server responses and identify vulnerabilities.

v) Sequencer

It analyzes the randomness and predictability of session tokens and other security sensitive values.

vi) Decoder

Encodes and decodes data in various formats, helping testers understand and analyze application data.

vii) Extender

Allows users to install or develop extensions (BApps) to add new features and customize Burp suite

viii) Scanner

It automatically scans web app for common security vulnerabilities, such as SQL injection and cross-site scripting. It is available in Burp Suite Professional and Enterprise edition.

2. ZAP (Zed Attack Proxy)

It is an open source web app security testing tool used to find vulnerabilities by intercepting and analyzing traffic between a browser and web server.

i) Proxy Server

It acts as an intermediary between a browser and a web server, allowing requests and responses to be inspected or modified.

ii) Spider

Automatically crawls a web application to discover pages, links, forms, and endpoints.



Mo	Tu	We	Th	Fr	Sa	Su
----	----	----	----	----	----	----

Memo No. _____

Date

/

/

iii) Passive Scan

Identifies potential vulnerabilities by analyzing traffic without sending additional attack requests to the target.

iv) Active Scan

It sends specially crafted requests to an authorized target to identify potential vulnerabilities.